CROSS-ORG AI AGENTS

Your agent passed every auth check. It still got more access.

6 places agent authority leaks when it crosses into another company's identity system.

9 SLIDES - SAVE FOR YOUR NEXT AGENT DESIGN REVIEW

Jatin Mishra

Made with GAMMA

01 · ACTOR

Which agent is really acting?

Company B gets a request: agent X, on behalf of user Y.

Can B verify either claim, or does it just trust the token?

Made with GAMMA

02 · FOUNDATION

Do the two domains really trust each other's keys?

B accepts assertions signed by A.

Ask how B learns when A rotates keys or a key is compromised.

Made with GAMMA

03 · PROTECTED RESOURCE

Same ID, different thing

An identifier from A's directory can point to a different entity in B's directory.

Or to nothing at all.

Made with GAMMA

04 · BOUNDARY REINTERPRETATION

orders:read goes in. orders:* comes out.

A narrow scope gets mapped to a broader local permission.

Classic confused deputy: a trusted service uses its own wider rights.

Made with GAMMA

05 · LIFECYCLE

The task ends. The access does not.

Task-scoped tokens keep working after the job is done.

Revoking the parent token never reaches the child tokens.

Made with GAMMA

06 · CROSS-CUTTING

Tokens leak, then get replayed

Bloated headers and verbose responses carry tokens to places they should not go.

Someone reuses them.

Made with GAMMA

DESIGN CHECKLIST

Check these before an agent crosses a boundary

1. Scopes: Exact-match scope map. No wildcards.
2. TTL: Tokens bound to the task, not the session.
3. Revocation: Cascade revocation to child tokens.
4. Config: Treat a config change as re-authorisation.
5. Timing: Check at authorisation time, not after the fact.

Made with GAMMA

SOURCE: OPENID FOUNDATION AIIM CG, OCT 2026

A threat model, not a standard. Design against it anyway.

Save this for your next cross-org agent design review.

Made with GAMMA